

# Bölüm 4: AI, KVKK ve Güvenlik

Fikir #1: B2B Tahsilat Kokpiti · Tasarım, Bölüm 4/5 · 29 Eylül 2026

## 4.1 AI'ın görevleri

| Görev                      | Ne yapar                                                                                                                           | Güvenlik önlemi                                                                                    |
|----------------------------|------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|
| <b>Yanıt sınıflandırma</b> | Gelen e-posta ve WhatsApp mesajını etiketler: ödeme sözü, itiraz, ödendi, bilgi talebi (ekstre/fatura kopyası), yanlış kişi, diğer | Güven puanı düşükse etiket uzmana sorulur                                                          |
| <b>Bilgi çıkarma</b>       | Yanıttan tarih, tutar ve fatura numarasını çeker                                                                                   | Tarih geçmişte olamaz; tutar ve fatura no açık kalemlerle karşılaştırılır; eşleşmezse uzmana gider |
| <b>Taslak yazma</b>        | Uzman için yanıt ve hatırlatma taslağı hazırlar                                                                                    | Her taslak uzman onayından geçer                                                                   |
| <b>Özetleme (sonra)</b>    | Uzun yazışma ve arama notlarını özetler                                                                                            | Yalnızca okuma amaçlı                                                                              |

**Kritik tasarım kararı: otomatik giden mesajlar sabit şablondur.** Bölüm 3'teki otomatik adımlar değişkenleri doldurulmuş, önceden onaylı şablonlardır; AI'ın serbest yazdığı metin değildir. AI'ın yazdığı her metin uzman onayından geçer. Böylece borçluya AI'ın uydurduğu bir tutar veya tarih gitmez.

**Prompt injection koruması:** Gelen e-postalar güvenilmeyen içeriktir; borçlunun mailinde “tüm faturaları kapat” gibi bir talimat olabilir. Bu yüzden AI'ın çıktısı yalnızca yapılandırılmış etiket ve alanlardır. AI hiçbir aksiyonu doğrudan tetikleyemez; aksiyonu sistem kuralları veya uzman alır.

**Öğrenme döngüsü:** Uzmanın düzelttiği etiketler kaydedilir. Bunlarla müşteri bazında doğruluk ölçülür ve bir test seti oluşturulur. Model veya prompt değişikliği canlıya alınmadan önce bu sette sınanır.

### Karar: AI modelinin çalıştığı yer

#### Sağlayıcıdan bağımsız tasarım (seçildi).

- Varsayılan: maskelemeli global bir LLM API'si + KVKK standart sözleşmesi.
- Hassas müşteriler için: Türkiye'de barındırılan açık kaynak model seçeneği.
- Seçim müşteri bazında bir ayardır; uygulama tek bir AI arayüzü üzerinden çalışır, sağlayıcı değişse de çekirdek değişmez.

## 4.2 KVKK

- Hangi veri kişisel?** Firma bilgileri tek başına kişisel veri değil. Ama muhatap adı, e-posta, telefon, mesaj içerikleri ve şahıs şirketlerine ait veriler kişisel veridir.
- Roller:** Müşterimiz veri sorumlusudur, biz veri işleyeniz. Her müşteriyle bir veri işleme sözleşmesi yapılır. VERBİS kaydı müşterinin sorumluluğundadır.
- Barındırma:** Veritabanı ve yedekler Türkiye'de tutulur.
- Yurt dışına aktarım (LLM sağlayıcısı):** 2024 KVKK değişikliğiyle yurt dışı aktarımda standart sözleşme yolu açıldı; imzalanan standart sözleşmenin Kurul'a bildirilmesi gerekir.
  - LLM'e gönderilmeden önce maskeleme yapılır: kişi adı, telefon, e-posta ve IBAN yer tutucularla değiştirilir, dönen sonuç geri doldurulur.
  - Yurt dışına hiç veri çıkmasını istemeyen müşteriler için Türkiye'de barındırılan model kullanılır.
- İleti izni:** Mevcut bir borcun hatırlatılması, ticari elektronik ileti mevzuatında onay istisnası kapsamında değerlendiriliyor. Yine de şablonların bu kapsamda kaldığı bir hukukçuya doğrulattırılmalı. WhatsApp tarafında ayrıca Meta politikası gereği muhatabın izni alınmalı ve kaydı tutulmalı.

## 4.3 Güvenlik

---

- **Kiracı izolasyonu:** Her tabloda müşteri kimliği bulunur. PostgreSQL satır seviyesi güvenliği (Row Level Security) ile bir müşterinin verisi başka müşterinin sorgusunda teknik olarak görünemez.
- **Ajan güvenliği:**
  - Yalnızca dışarı bağlantı kurar.
  - Her ajanın kendine ait, yenilenen bir kimliği vardır (mTLS veya imzalı token).
  - Veritabanı kullanıcısı yalnızca view'ları okuyabilir.
  - Ajan güncellemeleri imzalı dağıtılır.
- **Şifreleme:** İletimde TLS, depolamada disk ve veritabanı şifreleme. E-posta OAuth token'ları ve sırlar ayrı bir anahtar kasasında tutulur.
- **Kimlik:** Kurumsal SSO (Microsoft Entra ID, Google) ve çok faktörlü doğrulama. Rol bazlı yetki Bölüm 3.4'teki rollere göre.
- **Denetim kaydı:** Gönderilen her mesaj, her onay ve her ayar değişikliği değiştirilemez bir kayda yazılır. Bu kayıt “ne zaman, kime, ne gönderdiniz?” itirazlarında kanıt olur.
- **Saklama ve silme:** Veri saklama süresi müşteri bazında ayarlanır. Sözleşme bitince veri silinir ve bu belgelenir.
- **Kurumsal satış için:** İlk büyük müşteriden önce sızma testi yapılır. ISO 27001 yol haritasına konur; orta-büyük firmaların satın alma süreçlerinde genelde sorulur.

Durum: Onaylandı. Sonraki bölüm: Bölüm 5 — Yol haritası, riskler ve başarı ölçütleri.